

Reporte Ejecutivo de Riesgos y Mitigación

Destinatario: Directorio de la Clínica **Fecha:** 9 de septiembre de 2026

1. Resumen Ejecutivo

En el marco del plan de aseguramiento operativo de la clínica, se llevó a cabo un relevamiento integral de riesgos considerando nuestra infraestructura actual, el volumen de atención (800 pacientes diarios) y la cantidad de usuarios del sistema (120 empleados). Se identificaron un total de 7 riesgos operativos, legales y de seguridad de la información. El objetivo de este reporte es presentar las vulnerabilidades críticas y los planes de acción propuestos para garantizar la continuidad del servicio y la protección de los datos de nuestros pacientes.

2. Top 5 Riesgos por Nivel

Se priorizaron los siguientes riesgos en función de su probabilidad de ocurrencia e impacto potencial en la operación:

Ranking / Nivel	Riesgo Identificado	Impacto Operativo
1. Crítico	Ransomware en Historias Clínicas	Paralización total de la atención médica y pérdida de acceso a datos sensibles.
2. Crítico	Caída del validador de Obras Sociales	Freno inmediato en la facturación y validación de turnos en recepción.
3. Alto	Sanciones legales por fuga de datos	Daño reputacional y severas multas por incumplimiento de la Ley de Protección de Datos Personales.
4. Alto	Falla de hardware en servidor principal	Interrupción de la operación por desgaste del equipamiento físico.
5. Alto	Phishing a empleados de la clínica	Brecha de seguridad inicial a través de ataques de ingeniería social al personal.

3. Estado de los Planes de Acción

Actualmente, los planes de tratamiento para los riesgos más urgentes se encuentran aprobados e ingresando en la fase de ejecución. Su estado de avance es el siguiente:

- **[Plan Ransomware] Implementación de Backups EDR**
 - **Estado:** 0% (Planificado)
 - **Vencimiento:** Diciembre 2026
 - **Presupuesto Estimado:** \$100,001 a \$200,000
- **[Plan Validador] Enlace Backup y Pre-facturación Offline**
 - **Estado:** 0% (Planificado)
 - **Vencimiento:** Noviembre 2026
 - **Presupuesto Estimado:** \$0 a \$100,000
- **[Plan Phishing] Capacitación y 2FA**
 - **Estado:** 0% (Planificado)
 - **Vencimiento:** Octubre 2026
 - **Presupuesto Estimado:** \$0 a \$100,000

4. Recomendaciones Prioritarias

Para avanzar con la mitigación de los riesgos críticos, se solicita al Directorio:

1. **Aprobación de presupuesto:** Liberar los fondos de contingencia para la adquisición inmediata de licencias de software EDR y almacenamiento inmutable.
2. **Contratación de ISP secundario:** Agilizar la firma del contrato con un segundo proveedor de internet para aislar la dependencia del enlace actual.
3. **Carácter obligatorio:** Emitir una circular oficial desde Recursos Humanos estableciendo la obligatoriedad de la capacitación mensual en ciberseguridad para todo el personal, sin excepciones